

Vendor Risk Scoring Rubric — SecurityGroup101 GRC Program

Third-Party Risk Management · Based on CSA CCM v4.0 / CAIQ v4 · NIST SP 800-161 Rev 1 Supply Chain Risk Framework

Maxine Jones, GRC Analyst · mkj00015@mix.wvu.edu · July 2026

Purpose & Scoring Instructions

Purpose	Enables a GRC analyst to score and tier a vendor's security posture based on responses to a security questionnaire (CAIQ or equivalent). Use when reviewing inbound vendor questionnaires during third-party risk assessment.
Scoring Logic	Yes = Full weight value Partial = Weight × 0.5 No = 0 points N/A = Excluded from denominator
Risk Tier Thresholds	LOW ≥85% MEDIUM 70–84% HIGH 50–69% CRITICAL <50% OR any Critical red flag = No
Critical Red Flags	Questions marked [CRITICAL] represent minimum acceptable security baselines. A 'No' response to any Critical question automatically escalates the vendor to HIGH risk regardless of overall score.
Framework Basis	CSA Cloud Controls Matrix (CCM) v4.0 / CAIQ v4. Weights reflect risk significance per NIST SP 800-161 Rev 1 (Cybersecurity Supply Chain Risk Management). Developed by Maxine Jones as a GRC portfolio artifact.

Risk Tier Decision Guide

Risk Tier	Score Range	Recommended Action	Escalation Required
LOW	≥ 85%	Proceed with standard contract terms. Annual monitoring cadence.	None
MEDIUM	70 – 84%	Proceed with enhanced contract terms. Request remediation plan for identified gaps. Semi-annual monitoring.	Notify Security Manager
HIGH	50 – 69%	Escalate to CISO. Require documented remediation plan with committed timelines before contract execution. Quarterly monitoring.	CISO approval required
CRITICAL	< 50% OR Critical flag = No	Do not onboard without executive approval, legal review, and documented compensating controls with time-bound remediation.	Executive + Legal required

Assessment Questions

Complete the 'Vendor Response' column for each question based on the vendor's security questionnaire responses. Score: Yes = full weight, Partial = half weight, No = 0, N/A = excluded from score. Any 'No' on a [CRITICAL] question automatically triggers HIGH risk escalation.

#	Domain	Assessment Question	Wt	Flag	Vendor Response (Yes/No/Partial/N/A)	Analyst Notes
1	IAM	Is multi-factor authentication (MFA) required for all privileged and administrative access?	4	[CRITICAL] ■		
2	IAM	Is MFA required for all standard user access to production systems?	3	HIGH		
3	IAM	Is access provisioned on a least-privilege / need-to-know basis with defined RBAC?	3	HIGH		
4	IAM	Are formal user access reviews conducted at least annually?	2	MEDIUM		
5	IAM	Is there a formal offboarding process that removes all access within 24 hours of termination?	3	[CRITICAL] ■		
6	IAM	Are privileged accounts maintained separately from standard user accounts?	2	HIGH		
7	CEK	Is all customer data encrypted at rest using AES-256 or FIPS 140-2 validated equivalent?	4	[CRITICAL] ■		
8	CEK	Is all customer data encrypted in transit using TLS 1.2 or higher?	4	[CRITICAL] ■		
9	CEK	Is there a documented encryption key management policy with defined rotation schedules?	2	HIGH		
10	CEK	Are encryption keys stored separately from the data they protect?	3	HIGH		
11	SEF	Does the vendor have a documented and annually tested incident response plan?	3	HIGH		
12	SEF	Will the vendor notify customers within 72 hours of a confirmed data breach?	4	[CRITICAL] ■		
13	SEF	Are post-incident root cause analyses performed and documented?	2	MEDIUM		
14	SEF	Is there 24/7 security monitoring or on-call capability for incident response?	2	HIGH		
15	DSP	Is there a documented data classification and handling policy?	2	MEDIUM		
16	DSP	Does the vendor restrict data processing to contractually agreed geographic regions?	3	HIGH		

#	Domain	Assessment Question	Wt	Flag	Vendor Response (Yes/No/Partial/N/A)	Analyst Notes
17	DSP	Is there a documented data retention schedule and secure disposal policy?	2	MEDIUM		
18	DSP	Are Data Loss Prevention (DLP) controls deployed to detect data leakage?	2	MEDIUM		
19	DSP	Will the vendor return or certifiably delete all customer data within 30 days of contract termination?	3	[CRITICAL] ■		
20	LOG	Are security events logged with sufficient detail to support forensic investigation?	2	HIGH		
21	LOG	Are logs retained for a minimum of 12 months with 3 months online access?	2	MEDIUM		
22	LOG	Is a SIEM or equivalent security monitoring platform deployed?	2	HIGH		
23	LOG	Are critical security alerts reviewed and responded to within defined SLAs?	2	HIGH		
24	TVM	Are automated vulnerability scans performed on all production systems at least quarterly?	3	HIGH		
25	TVM	Are critical and high vulnerabilities remediated within 30 days of identification?	3	HIGH		
26	TVM	Is external penetration testing performed at least annually by an independent third party?	2	HIGH		
27	TVM	Is the CISA Known Exploited Vulnerabilities (KEV) catalog actively monitored?	1	MEDIUM		
28	GRC	Does the vendor have a SOC 2 Type II report or equivalent third-party security attestation?	3	HIGH		
29	GRC	Is there a documented information security policy approved by senior leadership?	2	MEDIUM		
30	GRC	Is security awareness training required for all employees at least annually?	2	MEDIUM		
31	GRC	Is there a documented risk assessment process conducted at least annually?	2	MEDIUM		
32	BCR	Does the vendor have a documented and tested Business Continuity Plan?	3	HIGH		
33	BCR	Are Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) defined for critical services?	2	HIGH		
34	BCR	Is customer data backed up with geographic (cross-region) redundancy?	2	HIGH		

#	Domain	Assessment Question	Wt	Flag	Vendor Response (Yes/No/Partial/N/A)	Analyst Notes
35	STA	Are subcontractors (fourth parties) with access to customer data disclosed to customers?	2	MEDIUM		
36	STA	Are subcontractors required to meet equivalent security standards as the primary vendor?	2	HIGH		

Total: 36 assessment questions · 90 maximum weighted points · 6 Critical red flags (any 'No' triggers HIGH risk escalation regardless of overall score).
Framework: CSA CCM v4.0 / CAIQ v4 · NIST SP 800-161 Rev 1 · Developed by Maxine Jones, GRC Analyst · SecurityGroup101 GRC Program ·
github.com/Mkjones10/securitygroup101-enterprise-grc-program